

DICHIARAZIONE DI ACCETTAZIONE DEL RISCHIO RESIDUO

Risk Acceptance Form

Accesso del personale SINOPEC a strumenti cloud-based corporate per le attività di: Construction Mechanical Completion

ID Documento	RAF-4503-SILLEN0-001
ID Rischio (Risk Register)	[RR-XXXX]
Progetto	4503-SILLEN0
Partner coinvolto	SINOPEC
Classificazione	Confidential — Internal Use Only
Risk Owner (titolari del rischio)	Construction Quality HoD; 4503 Silleno Project Director
Risk Assessor (funzione valutatrice)	TCMS Cybersecurity — Cyber Fusion Center / CISO

1. Contesto e motivazione

Nell'ambito del progetto 4503-SILLEN0, condotto in partnership con SINOPEC, la funzione TCMS Cybersecurity ha progettato e implementato misure di sicurezza dedicate alla protezione dei dati di progetto e delle risorse corporate, tra cui la segregazione dell'ambiente di progetto mediante risorse cloud dedicate. Tale architettura di segregazione costituisce **la soluzione raccomandata dalla funzione TCMS Cybersecurity** e ha ridotto in modo sostanziale il rischio di data leak e di compromissione delle risorse condivise.

Su richiesta delle funzioni di progetto, per comprovate esigenze operative connesse alla gestione delle attività di **Mechanical Completion**, è stato richiesto l'accesso di personale SINOPEC a strumenti cloud-based aziendali che, per loro natura, sono condivisi a livello corporate e con altri progetti, e che pertanto **esulano dal perimetro di segregazione raccomandato**.

Tali accessi introducono un rischio residuo che, pur valutato come basso alla luce delle misure di mitigazione applicate, **non è eliminabile** finché permane l'esigenza operativa rappresentata. La presente dichiarazione formalizza: (i) la valutazione del rischio condotta dalla funzione TCMS Cybersecurity; (ii) l'informativa resa ai Risk Owner; (iii) la decisione di accettazione del rischio, **assunta dai Risk Owner nell'esercizio delle proprie prerogative di business**, in conformità al sistema di controllo interno e di gestione dei rischi implementato per il gruppo.

2. Perimetro dell'eccezione

L'accesso del personale SINOPEC è autorizzato **esclusivamente** alle risorse e con le modalità di seguito indicate. **Ogni accesso eccedente il presente perimetro è da considerarsi non autorizzato** e fuori dall'ambito della presente accettazione.

Tool autorizzati	Microsoft Dynamics Field Service; IoT4MET DynoForms, Sharepoint dedicato alla MC. Nessun altro strumento corporate è incluso nel perimetro.
------------------	---

Finalità	Gestione delle attività di Mechanical Completion del progetto 4503-SILLEN0. Ogni uso per finalità diverse è escluso.
Tipologia utenze	Account nominativi individuali [guest/named], riconducibili a persona fisica identificata. Sono esclusi account condivisi, generici o di servizio.
Numero massimo utenze	60 utenze attive contemporaneamente.
Processo autorizzativo	Ogni utenza è attivata esclusivamente previa Service Request approvata dal Project Management, con tracciabilità di richiedente, approvatore e finalità. La responsabilità della congruità della richiesta è del richiedente e dell'approvatore di progetto.
Dati accessibili	Dati di progetto 4503-SILLEN0 pertinenti alla Mechanical Completion. La natura condivisa delle piattaforme non consente segregazione tecnica completa: tale limite architetturale è stato esplicitamente rappresentato ai Risk Owner ed è parte integrante del rischio accettato.

3. Valutazione del rischio (a cura del Risk Assessor)

ID	Scenario di rischio	Rischio inerente	Controlli applicati	Rischio residuo
R1	Esposizione accidentale di dati corporate o di altri progetti al partner, derivante dalla natura condivisa delle piattaforme	Medio (L: Possibile × I: Significativo)	Perimetrazione tassativa dei tool; autorizzazione individuale via Service Request; minimo privilegio; segregazione logica ove tecnicamente supportata	Basso
R2	Uso improprio o compromissione delle utenze partner, con accesso non autorizzato a risorse corporate	Medio (L: Possibile × I: Significativo)	MFA obbligatoria; Conditional Access [con eventuale geo-restriction]; monitoraggio continuativo CFC; alerting su anomalie; log retention conforme a policy; review periodica delle utenze	Basso
R3	Persistenza di accessi oltre l'esigenza operativa (utenze orfane non disattivate al termine delle attività o alla cessazione del personale partner), con esposizione prolungata non giustificata	Medio (L: Probabile × I: Moderato)	Review trimestrale delle utenze con disattivazione immediata di quelle non necessarie; scadenza automatica degli accessi alla data limite [ove tecnicamente configurabile]; obbligo di comunicazione delle variazioni di personale partner a carico del progetto	Basso
R4	Esfiltrazione di dati di progetto tramite funzionalità native delle piattaforme (export, download massivo, reportistica, condivisione esterna) da parte di utenze partner autorizzate	Medio-Alto (L: Possibile × I: Rilevante)	Profilazione al minimo privilegio con limitazione delle funzioni di export ove supportato; monitoraggio CFC su pattern di download anomali; [DLP / restrizioni di condivisione esterna a livello tenant]; tracciabilità completa delle operazioni nei log	Basso-Medio
R5	Compromissione delle credenziali partner per cause esterne al perimetro MAIRE (phishing o malware lato SINOPEC, igiene di sicurezza dei dispositivi partner non verificabile da MAIRE)	Medio (L: Possibile × I: Significativo)	MFA obbligatoria (mitiga il furto di sola password); Conditional Access [geo-restriction / blocco da reti anonimizzate]; detection CFC su accessi anomali (impossible travel, orari, IP atipici); revoca immediata in caso di sospetta compromissione	Basso

ID	Scenario di rischio	Rischio inerente	Controlli applicati	Rischio residuo
R6	Accesso da dispositivi non gestiti e non conformi agli standard MAIRE, fuori dal controllo della postura endpoint di gruppo	Medio (L: Probabile × I: Moderato)	[Accesso limitato a sessioni web senza persistenza locale dei dati / restrizioni su download da dispositivi non compliant via Conditional Access App Control, ove configurato]; monitoraggio sessioni; perimetrazione funzionale dei tool	Basso-Medio

Scala di valutazione conforme alla [Risk Management Procedure] di gruppo.

Limiti della valutazione. La valutazione è condotta sulla base delle informazioni rese disponibili dalle funzioni di progetto alla data di emissione e dell'architettura tecnica vigente. Variazioni del contesto operativo, del perimetro o delle informazioni fornite **non comunicate alla funzione TCMS Cybersecurity** rendono la presente valutazione non più rappresentativa, con gli effetti di cui alla Sezione 5.

Profili normativi e di tutela del patrimonio informativo. La presente valutazione ha ad oggetto esclusivamente i profili di sicurezza delle informazioni. I profili di export control, protezione della proprietà intellettuale e trasferimento di dati personali extra-UE **non rientrano nel perimetro di competenza della funzione TCMS Cybersecurity** e sono demandati alla valutazione della Funzione Legal / DPO / Compliance, come previsto dalle procedure esistenti. I Risk Owner prendono atto che la presente accettazione non sostituisce tali valutazioni.

4. Misure di mitigazione e condizioni di efficacia

Le seguenti misure costituiscono **condizioni essenziali di efficacia** della presente accettazione. Il loro mancato rispetto da parte delle funzioni di progetto determina la decadenza dell'accettazione ai sensi della Sezione 5.

A carico della funzione TCMS Cybersecurity (CFC):

1. Mantenimento dei controlli tecnici di accesso (MFA, Conditional Access, minimo privilegio);
2. Monitoraggio continuativo delle attività delle utenze partner, con detection dedicate e alerting su anomalie;
3. Conservazione dei log secondo i termini di retention di policy.

A carico del Project Management e dei Risk Owner:

4. Ricognizione periodica delle utenze attive, con disattivazione immediata di quelle non più necessarie e comunicazione dell'esito alla funzione TCMS Cybersecurity. **La mancata esecuzione della review costituisce violazione delle condizioni di efficacia;**
5. Richiesta di disattivazione delle utenze entro [5] giorni lavorativi dal venir meno dell'esigenza operativa;
6. Comunicazione tempestiva alla funzione TCMS Cybersecurity di ogni variazione del contesto (nuove esigenze di accesso, variazioni del personale partner, modifiche di scope progettuale);
7. Vigilanza sull'operato del personale partner nell'ambito delle attività di progetto, che rimane responsabilità delle funzioni di progetto e **non è trasferita alla funzione TCMS Cybersecurity** dal monitoraggio tecnico di cui al punto 2.

5. Validità, decadenza e revoca

Decorrenza	Data di sottoscrizione.
Scadenza	Completamento della Mechanical Completion, e comunque non oltre [data limite], maggiorata di 30 giorni tecnici per la dismissione ordinata degli accessi.
Revisione periodica	Trimestrale, a cura del Risk Assessor.
Decadenza automatica	L'accettazione decade automaticamente , senza necessità di comunicazione, in caso di: (i) violazione delle condizioni di cui alla Sezione 4 imputabile alle funzioni di progetto; (ii) accessi o usi eccedenti il perimetro di cui alla Sezione 2; (iii) omessa comunicazione di variazioni rilevanti del contesto. In tali casi, gli eventi occorsi in regime di decadenza non sono coperti dalla presente accettazione .
Revisione straordinaria	Incidente di sicurezza sulle utenze partner; modifica del perimetro; variazione significativa del contesto di rischio o del quadro normativo.
Revoca immediata	La funzione TCMS Cybersecurity si riserva la facoltà di sospendere o revocare con effetto immediato e unilaterale gli accessi del partner, in tutto o in parte, al verificarsi di anomalie, violazioni o evidenze di compromissione, senza necessità di preventiva approvazione dei Risk Owner e senza che ciò possa costituire inadempimento verso il progetto. Ai Risk Owner è data tempestiva comunicazione.
Rinnovo	Ogni proroga richiede nuova valutazione e nuova sottoscrizione. Non sono ammessi rinnovi taciti.

6. Parere della funzione TCMS Cybersecurity (Risk Assessor)

La funzione Cybersecurity, esaminati il contesto operativo, il perimetro dell'eccezione e le misure di mitigazione:

- **conferma** che la soluzione raccomandata rimane la piena segregazione delle risorse, e che l'eccezione qui formalizzata risponde a esigenze operative rappresentate dalle funzioni di progetto;
- **valuta** il rischio residuo come **Basso**, condizionatamente al pieno rispetto delle misure di cui alla Sezione 4;
- **ritiene** l'accettazione compatibile con la postura di sicurezza di gruppo, nei limiti e alle condizioni del presente documento.

Il presente parere ha natura **consultiva e di valutazione tecnica**. Esso non costituisce accettazione del rischio, né trasferisce alla funzione TCMS Cybersecurity alcuna titolarità del rischio o responsabilità per le conseguenze della decisione di accettazione, **che rimangono integralmente in capo ai Risk Owner sottoscrittori**.

7. Dichiarazione di accettazione (Risk Owner)

I sottoscritti, nella loro qualità di Risk Owner, **dichiarano espressamente** di:

- essere stati **compiutamente informati** dalla funzione TCMS Cybersecurity del contesto, dei rischi identificati (R1, R2), dei limiti architetturali delle piattaforme condivise e delle potenziali conseguenze in caso di concretizzazione dei rischi;
- aver avuto la possibilità di richiedere chiarimenti e approfondimenti, e di averli ricevuti in misura ritenuta sufficiente ai fini della presente decisione;
- essere consapevoli che la soluzione raccomandata dalla funzione TCMS Cybersecurity è la piena segregazione, e che la presente eccezione è richiesta **per esigenze operative delle funzioni di progetto**;
- **accettare espressamente il rischio residuo** identificato, assumendone la piena;
- assumere gli impegni di cui alla Sezione 4 (punti 4–7) e prendere atto delle condizioni di decadenza e revoca di cui alla Sezione 5;
- prendere atto che la funzione TCMS Cybersecurity, avendo reso la valutazione e l'informativa di cui al presente documento, **non assume alcuna responsabilità** per le conseguenze derivanti dalla decisione di accettazione qui formalizzata.

Ruolo	Nominativo	Data	Firma
Construction Quality HoD	Roberto Carlin		 Digitally signed by Carlin Roberto DN: CN=Carlin Roberto Date: 2026.06.11 12:47:45+02'00'
4503 Silleno Project Director	Carlo De Simone		 Carlo De Simone JV Project Director 2026.06.11 13:07:21+02'00'